GCVE BCP-05-X-03 - Vulnerability Handling and Disclosure Timeline

GCVE.eu

GCVE.eu

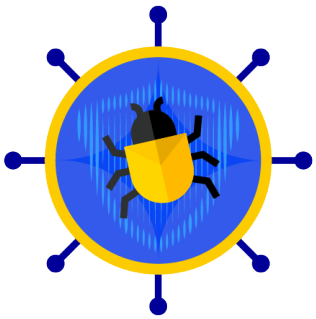
Contents

1 GCVE BCP-05-X-03: Vulnerability Handling and Disclosure Timeline 1

1.1 Abstract . . . 1
1.2 Motivation . . . 2
1.3 Placement . . . 4
1.4 Data Model . . . 4
1.5 Entity Registry . . . 5
1.5.1 Entity Fields . . . 6
1.5.2 Entity Categories . . . 7
1.6 Handling and Disclosure Events . . . 7
1.6.1 Event Fields . . . 8
1.6.2 Event Types . . . 10
1.7 Event Relationships . . . 13
1.8 Legacy Actor Values . . . 14
1.9 Regulatory Timeline . . . 15
1.9.1 Regulatory Fields . . . 16
1.9.2 Assessment Values . . . 17
1.10 Regulatory Notification Object . . . 17
1.10.1 Notification Status . . . 18
1.11 European Union Cyber Resilience Act Profile . . . 18
1.11.1 `early-warning` . . . 19
1.11.2 `vulnerability-notification` . . . 19
1.11.3 `final-report` . . . 19
1.11.4 CRA Example . . . 20
1.12 Relationship Between BCP-02 and Regulatory Timelines . . . 23
1.13 Public Disclosure and Corrective Measures . . . 24
1.14 Historical Events Versus Workflow State . . . 25
1.15 CSAF 2.1 Interoperability . . . 26
1.15.1 Scope . . . 26
1.15.2 CSAF Action Categories . . . 27
1.15.3 CSAF Action Status . . . 27

1.15.4 Mapping of Common Events . . . 28
1.15.5 Entity Mapping . . . 30
1.15.6 Event and Action References . . . 31
1.15.7 Summary and Description . . . 31
1.15.8 Dates . . . 31
1.15.9 Completed Actions . . . 32
1.15.10 Attempted Actions . . . 32
1.15.11 Planned Actions . . . 33
1.15.12 In-progress, Outstanding, Deferred, and Discontinued Actions . . . 33
1.16 CSAF Semantics Not Fully Represented by X-03 . . . 34
1.17 X-03 Semantics Not Fully Represented by CSAF . . . 34
1.18 Embargo Interoperability . . . 35
1.19 Regulatory Interoperability . . . 35
1.20 Example: CSAF-aligned Coordination Timeline . . . 36
1.21 Processing and Validation Requirements . . . 39
1.22 Updates and Corrections . . . 40
1.23 Privacy and Security Considerations . . . 41
1.24 Legal and Regulatory Considerations . . . 42
1.25 Interoperability Considerations . . . 42
1.26 Minimal Example . . . 43
1.27 Minimal Multi-party Example . . . 44
1.28 Example JSON Paths . . . 45
1.29 Relationship to Other GCVE BCPs . . . 46

1 GCVE BCP-05-X-03: Vulnerability Handling and Disclosure Timeline



GCVE.eu

- **Version**: 1.1
- **Status**: Draft
- **Date**: 2026-10-04
- **Authors**: GCVE Working Group
- **BCP Extended ID**: BCP-05
- **BCP ID**: BCP-05-X-03

This guide is distributed and available under CC-BY-4.0.

Copyright (C) 2026 GCVE Initiative.

1.1 Abstract

This document defines an extension to GCVE BCP-05 for representing the handling, coordination, remediation, disclosure, and regulatory notification timeline associated with a vulnerability advisory.

The extension provides a machine-readable representation of significant events during the vulnerability lifecycle, following the principles described in GCVE BCP-02 — Practical Guide to Vulnerability Handling and Disclosure.

It additionally provides an optional mechanism for recording regulatory notification milestones, including timelines associated with the European Union Cyber Resilience Act (CRA), without conflating regulatory notification with coordinated vulnerability disclosure or public publication.

This revision introduces optional mechanisms to identify entities participating in vulnerability handling, to express actions between entities, and to relate events to earlier events. These additions improve interoperability with coordination-oriented formats such as the CSAF 2.1 `involvement` model while preserving the event-oriented semantics of this extension.

The objective is to improve transparency, interoperability, process analysis, and automation while preserving the distinction between:

- vulnerability discovery and reporting;
- acknowledgement and validation;
- coordinated vulnerability disclosure;
- remediation and availability of corrective measures;
- deployment of corrective measures;
- public advisory publication;
- regulatory notifications;
- historical facts; and
- current or planned workflow state.

1.2 Motivation

GCVE BCP-02 recommends that vulnerability advisories include a discovery and disclosure timeline describing significant events such as when a vulnerability was reported, fixed, and publicly disclosed.

In practice, vulnerability handling contains considerably more useful information than these three dates. A complete process may include:

- initial discovery;
- report submission;
- failed or successful notification attempts;
- acknowledgement;
- vulnerability validation;
- identifier allocation;
- coordination with affected parties;
- agreement or modification of an embargo;
- development and testing of remediation;

- availability of a workaround;
- availability of a corrective measure;
- deployment of a corrective measure;
- detection of active exploitation;
- disagreement or dispute concerning an earlier handling event;
- public disclosure; and
- regulatory notification.

Recording these events in a structured form enables vulnerability databases, CSIRTs, GNAs, CNAs, vendors, open-source projects, researchers, CVD platforms, advisory producers, and other coordination systems to exchange and analyse handling timelines consistently.

Different vulnerability interchange formats model the handling process differently. Some formats describe a sequence of factual events. Others model actions between entities and can additionally describe whether an action is planned, in progress, outstanding, or completed.

This extension intentionally models **events that occurred** rather than the complete workflow state of a vulnerability-handling process.

For example:

```
fix-available
```

means that a corrective measure became available.

It does not mean:

```
a fix is planned
```

or:

```
a fix is currently being developed
```

unless corresponding factual events are separately represented.

This distinction is important for interoperability and for avoiding ambiguity between historical facts and current process state.

Regulatory requirements can introduce additional deadlines that are related to, but distinct from, the CVD process. For example, under the European Union Cyber Resilience Act, a manufacturer becoming aware of an actively exploited vulnerability may be subject to specific notification deadlines.

This extension therefore models operational vulnerability-handling events separately from regulatory notification requirements.

1.3 Placement

The extension MUST be placed in the `extensions` object of a GCVE BCP-05 record using the key `bcp-05-x-03`.

Its value MUST contain one `x_timeline` object.

```
{
  "x_gcve": [
    {
      "vulnId": "GCVE-1-2026-12345",
      "recordType": "advisory",
      "extensions": {
        "bcp-05-x-03": {
          "x_timeline": {
            "events": [],
            "entities": [],
            "regulatory": []
          }
        }
      }
    }
  ]
}
```

The `events` member is REQUIRED.

The `entities` member is OPTIONAL.

The `regulatory` member is OPTIONAL.

1.4 Data Model

The `x_timeline` object contains:

Field	Type	Required	Description
`events`	array of objects	yes	Chronological vulnerability handling and disclosure events.
`entities`	array of objects	no	Entities participating in or referenced by timeline events.

Field	Type	Required	Description
`regulatory`	array of objects	no	Regulatory assessments and notification timelines associated with the vulnerability.

The three components have distinct purposes:

```
entities
   |
   +---- identity and role of participants

events
   |
   +---- factual history of vulnerability handling

regulatory
   |
   +---- regulatory assessment and notification milestones
```

1.5 Entity Registry

The optional `entities` array allows timeline events to refer to participating entities without repeating their identity in every event.

The registry is particularly useful when:

- several organizations participate in vulnerability coordination;
- notifications or acknowledgements need an explicit sender and recipient;
- an event refers to another organization rather than only to a generic role;
- a timeline is converted to or from an action-oriented format such as CSAF;
- the same organization participates in several different roles during the handling process.

Example:

```
{
  "entities": [
    {
      "id": "entity-researcher",
      "category": "discoverer",
      "name": "Example Researcher"
```

```
    },
    {
      "id": "entity-vendor",
      "category": "vendor",
      "name": "Example Vendor"
    },
    {
      "id": "entity-coordinator",
      "category": "coordinator",
      "name": "Example CSIRT"
    }
  ]
}
```

1.5.1 Entity Fields

Field	Type	Required	Description
`id`	string	yes	Identifier unique within the `x_timeline` object.
`category`	string	yes	General category of the entity.
`name`	string	no	Human-readable name of the entity.
`description`	string	no	Additional non-sensitive information about the entity.
`references`	array of strings	no	Public references identifying or describing the entity.

An entity identifier is local to the containing `x_timeline` object and MUST NOT be interpreted as a globally unique identifier.

The `name` field is OPTIONAL because an entity may be anonymous, unknown, confidential, or deliberately represented only by its functional category.

1.5.2 Entity Categories

For interoperability with CSAF and other coordination formats, the following values SHOULD be used when applicable:

- `adversary`
- `coordinator`
- `discoverer`
- `multiplier`
- `other`
- **`public`**
- `reporting_authority`
- `user`
- `vendor`

The categories identify the general nature of the entity and do not constrain whether that entity can initiate or receive a particular event.

For example:

```
discoverer -> reported -> vendor
vendor -> acknowledged -> discoverer
coordinator -> affected-party-notified -> vendor
vendor -> regulatory notification -> reporting_authority
vendor -> public-disclosure -> public
```

An implementation MUST NOT infer that an entity has only one operational role merely because one category is specified.

The category vocabulary intentionally differs from the legacy `actor` role vocabulary described later in this document.

1.6 Handling and Disclosure Events

Each member of `events` represents a significant factual event in the vulnerability lifecycle.

Example:

```
{
  "id": "evt-3",
  "type": "validated",
  "timestamp": "2026-09-10T14:20:00Z",
  "actor": "vendor",
  "actorRefs": [
```

```
    "entity-vendor"
  ],
  "description": "The vulnerability was reproduced and confirmed."
}
```

An event involving two parties can additionally identify the recipient:

```
{
  "id": "evt-report",
  "type": "reported",
  "timestamp": "2026-09-08T08:15:00Z",
  "actor": "researcher",
  "actorRefs": [
    "entity-researcher"
  ],
  "recipientRefs": [
    "entity-vendor"
  ],
  "description": "The vulnerability report was sent to the vendor."
}
```

An event may also refer to an earlier event:

```
{
  "id": "evt-ack",
  "type": "acknowledged",
  "timestamp": "2026-09-08T09:02:00Z",
  "actor": "vendor",
  "actorRefs": [
    "entity-vendor"
  ],
  "recipientRefs": [
    "entity-researcher"
  ],
  "referencedEvents": [
    "evt-report"
  ],
  "description": "The vendor acknowledged receipt of the vulnerability
     report."
}
```

1.6.1 Event Fields

Field	Type	Required	Description
`id`	string	yes	Identifier unique within the timeline.

Field	Type	Required	Description
`type`	string	yes	Type of vulnerability lifecycle event.
`timestamp`	string	yes	ISO 8601 date or RFC 3339 date-time at which the event occurred.
`actor`	string	no	General role primarily responsible for or associated with the event.
`actorRefs`	array of strings	no	References to entities that performed or initiated the event.
`recipientRefs`	array of strings	no	References to entities that received or were directly targeted by the event.
`referencedEvents`	array of strings	no	IDs of earlier or otherwise related events in the same timeline.
`description`	string	no	Human-readable description of the event.
`references`	array of strings	no	Public references providing supporting information about the event.

When a precise time is known, an RFC 3339 date-time SHOULD be used and UTC (`Z`) SHOULD be preferred.

When only a calendar date is reliably known, an ISO 8601 full date MAY be used.

`actorRefs`, `recipientRefs`, and `referencedEvents` MUST NOT contain duplicate values.

When `actorRefs` or `recipientRefs` are present, each value MUST reference an existing `entities[].id` in the same `x_timeline` object.

Every value in `referencedEvents` MUST reference an existing `events[].id` in the same `x_timeline` object.

An implementation SHOULD use `referencedEvents` only where the relationship between the events is meaningful.

Examples include:

- an acknowledgement referring to the original report;
- a dispute referring to an earlier validation or coordination event;
- an updated advisory referring to its publication event;
- an embargo extension referring to the previously agreed embargo;
- a fix deployment referring to the corresponding `fix-available` event.

1.6.2 Event Types

The following event types are defined:

Event type	Description
`discovered`	The vulnerability was initially discovered.
`reported`	The vulnerability was reported to a vendor, maintainer, coordinator, GNA, CNA, or other appropriate party.
`notification-attempted`	An attempt was made to notify an intended recipient, but successful delivery or receipt was not established.
`received`	The vulnerability report was received by the handling organization.
`acknowledged`	Receipt of the vulnerability report was acknowledged.
`triaged`	Initial security triage was performed.
`validated`	The vulnerability was reproduced, confirmed, or otherwise validated.

Event type	Description
`rejected`	The report was determined not to represent a vulnerability or was otherwise rejected.
`disputed`	A party disputed an earlier event, assessment, action, severity determination, affected-product claim, remediation claim, or other handling assertion.
`identifier-assigned`	A GCVE, CVE, or other vulnerability identifier was assigned.
`coordination-started`	Coordinated vulnerability handling involving one or more parties began.
`affected-party-notified`	An affected vendor, maintainer, downstream project, or other relevant party was notified.
`embargo-agreed`	A coordinated disclosure or embargo date was agreed.
`embargo-extended`	An existing coordinated disclosure deadline was extended.
`remediation-started`	Development of a corrective or mitigating measure began.
`mitigation-available`	A workaround or temporary mitigation became available.
`fix-developed`	A corrective change was developed but was not necessarily publicly available.
`fix-available`	A security update, patch, corrected release, or other corrective measure became available to users.
`fix-deployed`	A corrective measure was deployed or installed by an affected user, operator, downstream party, or other entity.
`exploit-observed`	Exploitation of the vulnerability was observed or reliably established.
`public``-disclosure-planned`	A public disclosure date was established.

Event type	Description
public-disclosure	Vulnerability information was publicly disclosed.
advisory-published	A vulnerability advisory was published.
advisory-updated	A previously published advisory was materially updated.
case-closed	The handling or coordination case was considered closed.
other	Another significant lifecycle event not covered by the defined vocabulary.

Event types are intended to describe **facts rather than workflow states**.

For example:

```
remediation-started
```

states that remediation work began.

It does not by itself state whether that work is currently:

```
in progress
deferred
discontinued
completed
```

Similarly:

```
fix-available
```

states that a corrective measure became available.

It MUST NOT be used merely because a corrective measure is planned or expected.

Producers MAY omit events that are unknown or not relevant.

Consumers MUST NOT infer that an omitted event did not occur.

Additional event types MAY be introduced in future revisions of this extension. Consumers MUST ignore event types they do not understand rather than rejecting the complete extension.

1.7 Event Relationships

`referencedEvents` provides a generic mechanism for expressing a relationship between factual timeline events.

The semantic meaning is primarily determined by the event containing the reference.

For example:

```
{
  "id": "evt-report",
  "type": "reported",
  "timestamp": "2026-09-08T08:15:00Z"
}
```

can be referenced by:

```
{
  "id": "evt-ack",
  "type": "acknowledged",
  "timestamp": "2026-09-08T09:02:00Z",
  "referencedEvents": [
    "evt-report"
  ]
}
```

to mean that the acknowledgement concerns the earlier report.

Similarly:

```
{
  "id": "evt-dispute",
  "type": "disputed",
  "timestamp": "2026-09-09T11:00:00Z",
  "referencedEvents": [
    "evt-validation"
  ],
  "description": "A downstream maintainer disputed the affected-product
      assessment."
}
```

indicates that the dispute concerns the referenced validation event.

The relationship MUST NOT be interpreted as chronological causality unless that interpretation follows from the event type or description.

A producer SHOULD NOT create cyclic event references.

1.8 Legacy Actor Values

The `actor` field provides a lightweight role representation and MAY use one of the following values:

- `reporter`
- `researcher`
- `vendor`
- `maintainer`
- `coordinator`
- `gna`
- `cna`
- `csirt`
- `regulator`
- `downstream`
- `other`

The role identifies the party associated with the event and does not require the publication of a natural person's identity.

The `actor` field is intentionally retained for lightweight implementations and backward compatibility.

Where more precise interoperability or multi-party coordination information is required, producers SHOULD use `actorRefs` and the optional entity registry.

The legacy actor values do not map one-to-one to entity categories.

For example:

Actor	Typical entity category
`researcher`	`discoverer`
`vendor`	`vendor`
`maintainer`	`vendor`
`coordinator`	`coordinator`
`csirt`	commonly `coordinator`
`regulator`	commonly `reporting_authority`
`reporter`	context-dependent
`gna`	context-dependent

Actor	Typical entity category
`cna`	context-dependent
`downstream`	context-dependent
`other`	`other`

A GNA, CNA, CSIRT, or downstream organization MUST NOT be assigned an entity category solely from its organizational designation. Its functional role in the represented coordination process SHOULD be used instead.

1.9 Regulatory Timeline

The optional `regulatory` array represents regulatory processes associated with the vulnerability.

Regulatory notification is distinct from public vulnerability disclosure.

A notification to a competent authority, national CSIRT, ENISA, or another regulatory recipient MUST NOT be represented as a **`public`**`-disclosure` event unless the vulnerability information was actually made public.

Each regulatory entry describes one regulatory framework or reporting regime.

Example:

```
{
  "framework": "EU-CRA",
  "jurisdiction": "EU",
  "assessment": "applicable",
  "trigger": "actively-exploited-vulnerability",
  "awarenessAt": "2026-09-10T10:00:00Z",
  "notifications": [
    {
      "type": "early-warning",
      "dueAt": "2026-09-11T10:00:00Z",
      "submittedAt": "2026-09-10T15:42:00Z",
      "status": "submitted",
      "channel": "CRA-SRP"
    },
    {
      "type": "vulnerability-notification",
      "dueAt": "2026-09-13T10:00:00Z",
      "submittedAt": "2026-09-12T08:30:00Z",
      "status": "submitted",
      "channel": "CRA-SRP"
```

```
    },
    {
      "type": "final-report",
      "triggerEvent": "evt-fix-available",
      "dueAt": "2026-09-30T09:00:00Z",
      "status": "pending",
      "channel": "CRA-SRP"
    }
  ]
}
```

1.9.1 Regulatory Fields

Field	Type	Required	Description
`framework`	string	yes	Regulatory framework or reporting regime.
`jurisdiction`	string	no	Jurisdiction associated with the framework.
`assessment`	string	yes	Publisher's current assessment of whether the reporting framework applies.
`trigger`	string	no	Event or condition potentially triggering the reporting requirement.
`awarenessAt`	string	no	Time at which the relevant organization became aware of the condition triggering the obligation.
`notifications`	array of objects	no	Notifications, reports, or other regulatory milestones.

Field	Type	Required	Description
`notes`	string	no	Additional non-sensitive context.

1.9.2 Assessment Values

The `assessment` field MUST use one of:

- `not-assessed`
- `not-applicable`
- `potentially-applicable`
- `applicable`

The value expresses the publisher's process assessment and MUST NOT be interpreted by consumers as an authoritative legal determination.

1.10 Regulatory Notification Object

Each regulatory notification MAY contain:

Field	Type	Required	Description
`type`	string	yes	Type of notification or regulatory milestone.
`triggerEvent`	string	no	`id` of an event in `events` that starts or materially affects the relevant deadline.
`dueAt`	string	no	Applicable deadline calculated by the producer.
`submittedAt`	string	no	Actual submission timestamp.
`status`	string	no	Current processing state.

Field	Type	Required	Description
`channel`	string	no	Reporting mechanism or platform used.
`reference`	string	no	Non-sensitive identifier or reference for the submission.
`basis`	string	no	Human-readable reference to the provision establishing the requirement.
`notes`	string	no	Additional non-sensitive context.

1.10.1 Notification Status

The `status` field SHOULD use one of:

- `pending`
- `submitted`
- `updated`
- `not-required`
- `withdrawn`

These values describe the state of a regulatory submission only.

They MUST NOT be interpreted as the current state of the vulnerability-handling process as a whole.

A `submitted` value MUST NOT by itself be interpreted as evidence of regulatory compliance.

1.11 European Union Cyber Resilience Act Profile

This extension defines `EU-CRA` as the conventional framework identifier for reporting associated with Regulation (EU) 2024/2847, the Cyber Resilience Act.

For an actively exploited vulnerability, an entry MAY use:

```
{
  "framework": "EU-CRA",
```

```
  "jurisdiction": "EU",
  "trigger": "actively-exploited-vulnerability"
}
```

When the publisher determines that the relevant CRA reporting requirement applies, `assessment` SHOULD be `applicable`.

The timeline MAY record the manufacturer's awareness time using `awarenessAt`.

For an actively exploited vulnerability, the following notification types are defined.

1.11.1 early-warning

Represents the early warning notification required without undue delay and, where applicable, within 24 hours after the manufacturer becomes aware of the actively exploited vulnerability.

Recommended `basis`:

```
Regulation (EU) 2024/2847 Article 14(2)(a)
```

1.11.2 vulnerability-notification

Represents the subsequent vulnerability notification required without undue delay and, where applicable, within 72 hours after awareness, unless the relevant information has already been provided.

Recommended `basis`:

```
Regulation (EU) 2024/2847 Article 14(2)(b)
```

1.11.3 final-report

Represents the final report associated with an actively exploited vulnerability.

The relevant deadline is based on the availability of a corrective or mitigating measure rather than the original awareness timestamp.

A **`final`**`-report` SHOULD therefore use `triggerEvent` to reference the corresponding `fix-available` or `mitigation-available` event when that event is represented in the timeline.

Recommended `basis`:

```
Regulation (EU) 2024/2847 Article 14(2)(c)
```

For CRA actively exploited vulnerability reporting, the final report is, where applicable, due no later than 14 days after a corrective or mitigating measure becomes available.

1.11.4 CRA Example

```
{
  "x_gcve": [
    {
      "vulnId": "GCVE-1-2026-12345",
      "recordType": "advisory",
      "extensions": {
        "bcp-05-x-03": {
          "x_timeline": {
            "entities": [
              {
                "id": "entity-researcher",
                "category": "discoverer",
                "name": "Example Researcher"
              },
              {
                "id": "entity-vendor",
                "category": "vendor",
                "name": "Example Vendor"
              },
              {
                "id": "entity-authority",
                "category": "reporting_authority"
              },
              {
                "id": "entity-public",
                "category": "public"
              }
            ],
            "events": [
              {
                "id": "evt-discovery",
                "type": "discovered",
                "timestamp": "2026-09-07",
                "actor": "researcher",
                "actorRefs": [
                  "entity-researcher"
                ]
              },
              {
                "id": "evt-report",
                "type": "reported",
                "timestamp": "2026-09-08T08:15:00Z",
                "actor": "researcher",
                "actorRefs": [
                  "entity-researcher"
                ],
                "recipientRefs": [
                  "entity-vendor"
                ]
```

```
    },
    {
      "id": "evt-ack",
      "type": "acknowledged",
      "timestamp": "2026-09-08T09:02:00Z",
      "actor": "vendor",
      "actorRefs": [
        "entity-vendor"
      ],
      "recipientRefs": [
        "entity-researcher"
      ],
      "referencedEvents": [
        "evt-report"
      ]
    },
    {
      "id": "evt-validation",
      "type": "validated",
      "timestamp": "2026-09-09T13:30:00Z",
      "actor": "vendor",
      "actorRefs": [
        "entity-vendor"
      ]
    },
    {
      "id": "evt-exploitation",
      "type": "exploit-observed",
      "timestamp": "2026-09-10T10:00:00Z",
      "actor": "vendor",
      "actorRefs": [
        "entity-vendor"
      ],
      "description": "Evidence established that the
         vulnerability was being actively exploited."
    },
    {
      "id": "evt-mitigation",
      "type": "mitigation-available",
      "timestamp": "2026-09-10T17:00:00Z",
      "actor": "vendor",
      "actorRefs": [
        "entity-vendor"
      ]
    },
    {
      "id": "evt-fix-available",
      "type": "fix-available",
      "timestamp": "2026-09-16T09:00:00Z",
      "actor": "vendor",
      "actorRefs": [
```

```
100                     "entity-vendor"
101                   ],
102                   "description": "Security update made available to users
                        ."
103                 },
104                 {
105                   "id": "evt-disclosure",
106                   "type": "public-disclosure",
107                   "timestamp": "2026-09-16T09:15:00Z",
108                   "actor": "vendor",
109                   "actorRefs": [
110                     "entity-vendor"
111                   ],
112                   "recipientRefs": [
113                     "entity-public"
114                   ]
115                 },
116                 {
117                   "id": "evt-advisory",
118                   "type": "advisory-published",
119                   "timestamp": "2026-09-16T09:15:00Z",
120                   "actor": "vendor",
121                   "actorRefs": [
122                     "entity-vendor"
123                   ],
124                   "recipientRefs": [
125                     "entity-public"
126                   ]
127                 }
128               ],
129               "regulatory": [
130                 {
131                   "framework": "EU-CRA",
132                   "jurisdiction": "EU",
133                   "assessment": "applicable",
134                   "trigger": "actively-exploited-vulnerability",
135                   "awarenessAt": "2026-09-10T10:00:00Z",
136                   "notifications": [
137                     {
138                       "type": "early-warning",
139                       "dueAt": "2026-09-11T10:00:00Z",
140                       "submittedAt": "2026-09-10T15:42:00Z",
141                       "status": "submitted",
142                       "channel": "CRA-SRP",
143                       "basis": "Regulation (EU) 2024/2847 Article 14(2)(a
                            )"
144                     },
145                     {
146                       "type": "vulnerability-notification",
147                       "dueAt": "2026-09-13T10:00:00Z",
148                       "submittedAt": "2026-09-12T08:30:00Z",
```

```
                    "status": "submitted",
                    "channel": "CRA-SRP",
                    "basis": "Regulation (EU) 2024/2847 Article 14(2)(b)"
                  },
                  {
                    "type": "final-report",
                    "triggerEvent": "evt-fix-available",
                    "dueAt": "2026-09-30T09:00:00Z",
                    "status": "pending",
                    "channel": "CRA-SRP",
                    "basis": "Regulation (EU) 2024/2847 Article 14(2)(c)"
                  }
                ]
              }
            ]
          }
        }
      }
    ]
}
```

1.12 Relationship Between BCP-02 and Regulatory Timelines

GCVE BCP-02 defines practical recommendations for coordinated vulnerability handling and disclosure.

The events represented by this extension provide a machine-readable expression of that process.

In particular:

```
discovered
    |
reported
    |
received / acknowledged
    |
triaged / validated
    |
coordination-started
    |
remediation-started
    |
mitigation-available / fix-developed
    |
fix-available
```

```
    |
public-disclosure / advisory-published
    |
case-closed
```

Individual cases MAY omit steps, contain additional steps, or execute several steps in parallel.

Additional interaction events can branch from this lifecycle:

```
reported ---------------------> acknowledged
    |
    +-------------------------> disputed

notification-attempted
    |
    +-------------------------> reported / affected-party-notified

fix-available -----------------> fix-deployed
```

Regulatory processes MAY branch from the timeline independently:

```
                    +--> regulatory awareness
                    |         |
validated/exploit--+         +--> early warning
                             |
                             +--> vulnerability notification
                             |
fix/mitigation available ----+--> final report
```

The existence of regulatory reporting MUST NOT modify the semantics of CVD events.

In particular:

- a CRA early warning is not a public disclosure;
- a CRA vulnerability notification is not an advisory publication;
- assignment of a GCVE or CVE identifier does not by itself trigger or satisfy a CRA reporting obligation;
- publication of a vulnerability advisory does not by itself satisfy a regulatory reporting requirement; and
- regulatory reporting does not by itself mean vulnerability information has been publicly disclosed.

1.13 Public Disclosure and Corrective Measures

BCP-02 recommends coordinating public disclosure with the availability of a fix or other protective measure whenever practical.

For products within the scope of applicable regulation, additional vulnerability-handling requirements may apply.

The operational timeline SHOULD therefore distinguish at least:

```
fix-developed
```

from:

```
fix-available
```

and from:

```
fix-deployed
```

and from:

```
public-disclosure
```

A fix can exist internally before it is available to users.

A fix can be available to users without having been deployed.

The availability of a corrective measure can itself trigger a regulatory deadline.

The deployment of a corrective measure by a user or operator does not imply that all affected systems have been remediated.

1.14 Historical Events Versus Workflow State

This extension records **historical events**.

It does not define the complete current workflow state of a vulnerability-handling case.

This distinction is intentional.

For example:

```
remediation-started
```

records the fact that remediation activity began.

It does not answer whether remediation is currently:

```
planned
in progress
outstanding
deferred
discontinued
```

```
completed
```

Likewise:

```
public-disclosure-planned
```

records the fact that a disclosure plan or disclosure date was established.

It does not itself provide a generic state machine for advisory publication.

Consumers MUST NOT reconstruct a definitive current workflow state solely from the presence or absence of timeline events unless the applicable process specification explicitly defines such a derivation.

A future or separate GCVE extension MAY define current vulnerability-handling or advisory-publication state.

Such state SHOULD remain separate from the factual timeline defined by this document.

1.15 CSAF 2.1 Interoperability

The CSAF 2.1 interoperability section is provided as a clarification to illustrate how the concepts defined by this extension can be mapped to another structured vulnerability-handling format without changing the semantics of BCP-05-X-03 itself. CSAF 2.1 is used here as a concrete example because it defines an explicit model for coordination actions and participating entities. The same interoperability principles may equally apply to other standards or formats that define, now or in the future, a structured vulnerability disclosure or handling timeline. Such mappings should preserve the distinction between factual lifecycle events, workflow state, coordination actions, and regulatory processes, rather than forcing different models into artificial one-to-one equivalence.

1.15.1 Scope

The OASIS Common Security Advisory Framework (CSAF) 2.1 introduces a document-level `involvement` model designed to represent coordination activities between entities.

The CSAF model and this extension overlap substantially but have different primary semantics.

CSAF primarily models:

```
acting entity
      |
      v
    action
```

```
      |
      v
receiving entity
```

and associates each action with a current action status.

BCP-05-X-03 primarily models:

```
factual event
      |
      +--> when it happened
      +--> who participated
      +--> which earlier events it relates to
```

The formats SHOULD therefore be considered interoperable but not semantically identical.

A converter MUST preserve these differences and MUST NOT invent facts solely to make one format structurally resemble the other.

1.15.2 CSAF Action Categories

The CSAF 2.1 involvement model defines action categories including:

- `confirmation`
- `coordination`
- `discovery`
- `dispute`
- `exploitation`
- `fix_deployment`
- `fix_release`
- `notification`
- `triage`

BCP-05-X-03 defines more specific vulnerability-handling events and therefore does not adopt these categories directly as event types.

1.15.3 CSAF Action Status

The CSAF action model can describe statuses including:

- `attempted`
- `completed`
- `deferred`

- `discontinued`
- `in_progress`
- `outstanding`
- `planned`

These values are action or workflow state.

They MUST NOT be copied directly into BCP-05-X-03 as generic event status values.

The following statement is valid in CSAF:

```
fix_release / planned
```

but MUST NOT be converted to:

```
fix-available
```

because a planned release is not evidence that a fix became available.

Similarly:

```
fix_release / outstanding
```

MUST NOT produce a `fix-available` event.

1.15.4 Mapping of Common Events

The following table provides interoperability guidance.

BCP-05-X-03 event	Typical CSAF action category	Typical CSAF status	Mapping
`discovered`	`discovery`	`completed`	Strong
`reported`	`notification`	`completed`	Strong when recipient is known
`notification-attempted`	`notification`	`attempted`	Strong
`received`	`confirmation`	`completed`	Partial
`acknowledged`	`confirmation`	`completed`	Strong when the original notification is referenced
`triaged`	`triage`	`completed`	Strong

BCP-05-X-03 event	Typical CSAF action category	Typical CSAF status	Mapping
`validated`	`triage`	`completed`	Partial; X-03 is more specific
`rejected`	`dispute`	`completed`	Conditional
`disputed`	`dispute`	`completed`	Strong
`coordination-started`	`coordination`	`in_progress` or `completed`	Conditional
`affected-party-notified`	`notification`	`completed`	Strong
`fix-available`	`fix_release`	`completed`	Strong
`fix-deployed`	`fix_deployment`	`completed`	Strong
`exploit-observed`	`exploitation`	`completed`	Strong
`public``-disclosure-planned`	`notification` to **`public`**	`planned`	Conditional
`public``-disclosure`	`notification` to **`public`**	`completed`	Conditional
`advisory-published`	no exact dedicated action	context-dependent	Partial
`embargo-agreed`	`coordination`	usually `completed`	Lossy
`embargo-extended`	`coordination`	usually `completed`	Lossy
`remediation-started`	no exact dedicated action	context-dependent	Lossy
`mitigation-available`	no exact dedicated action	context-dependent	Lossy
`fix-developed`	no exact dedicated action	context-dependent	Lossy
`identifier-assigned`	no exact dedicated action	context-dependent	No direct mapping

BCP-05-X-03 event	Typical CSAF action category	Typical CSAF status	Mapping
`case-closed`	no exact dedicated action	context-dependent	No direct mapping

`Strong` indicates that the concepts are sufficiently similar for straightforward conversion when the surrounding information agrees.

`Partial` indicates that one representation contains additional semantics that may not survive conversion.

`Conditional` indicates that actor, recipient, referenced actions, description, or surrounding context must be inspected before conversion.

`Lossy` indicates that a generic CSAF action can approximate the event but does not retain its full semantics.

`No direct mapping` indicates that no action category provides an equivalent representation.

1.15.5 Entity Mapping

When both formats use explicit entities, the following mapping is RECOMMENDED:

```
CSAF involvement.entities[].entity_id
                 |
                 v
BCP-05-X-03 entities[].id
```

CSAF entity categories can normally be copied directly to the X-03 entity `category` field.

The mapping of identities MUST remain local to the converted document or timeline unless a globally stable identifier is explicitly available.

The BCP-05-X-03 `actorRefs` field corresponds conceptually to CSAF:

```
acting_entity_refs
```

The BCP-05-X-03 `recipientRefs` field corresponds conceptually to CSAF:

```
receiving_entity_refs
```

A CSAF entity group SHOULD be expanded to its constituent entities when converted into BCP-05-X-03 unless the converter provides another documented mechanism for preserving group semantics.

1.15.6 Event and Action References

BCP-05-X-03:

```
referencedEvents
```

corresponds conceptually to CSAF:

```
referenced_action_ids
```

For example:

```
CSAF:
notification A
confirmation B -> references A
```

can be represented as:

```
X-03:
reported A
acknowledged B -> referencedEvents = [A]
```

A converter MUST NOT assume that every CSAF action reference represents acknowledgement.

The meaning of the relationship depends on the referring action category.

1.15.7 Summary and Description

CSAF:

```
summary
```

normally maps to:

```
description
```

in BCP-05-X-03.

A converter SHOULD preserve the original meaning and SHOULD NOT rewrite factual claims during format conversion.

1.15.8 Dates

CSAF action:

```
date
```

normally maps to:

```
timestamp
```

when the action represents an event that actually occurred.

For non-completed CSAF actions, the CSAF date MUST NOT automatically be treated as the time at which the corresponding factual X-03 event occurred.

For example:

```
category = fix_release
status = planned
date = 2026-09-10T10:00:00Z
```

does not establish:

```
fix-available at 2026-09-10T10:00:00Z
```

1.15.9 Completed Actions

A CSAF action with:

```
status = completed
```

MAY be converted to the corresponding X-03 factual event where the action category and surrounding context establish a sufficiently precise mapping.

For example:

```
category = fix_release
status = completed
```

can normally produce:

```
fix-available
```

1.15.10 Attempted Actions

A CSAF action with:

```
category = notification
status = attempted
```

can normally be represented using:

```
notification-attempted
```

A producer SHOULD preserve the intended recipient using `recipientRefs` when available.

1.15.11 Planned Actions

A CSAF action with:

```
status = planned
```

does not normally result in an X-03 event representing completion of that action.

An event MAY nevertheless represent the factual establishment of a plan.

For example, a sufficiently documented:

```
notification to public / planned
```

may correspond to:

```
public-disclosure-planned
```

provided that the event timestamp represents when the disclosure plan was established and not a falsely asserted publication time.

1.15.12 In-progress, Outstanding, Deferred, and Discontinued Actions

The CSAF statuses:

```
in_progress
outstanding
deferred
discontinued
```

describe workflow or observation state.

They generally have no direct equivalent in this extension.

A converter MUST NOT create completion events from these values.

A factual event MAY be generated when the status establishes that a distinct event occurred.

For example:

```
coordination / in_progress
```

may support a:

```
coordination-started
```

event if the action date actually represents the beginning of coordination.

This conversion is contextual and MUST NOT be applied blindly.

1.16 CSAF Semantics Not Fully Represented by X-03

CSAF includes document-level scoping for:

- document-local vulnerability identifiers;
- product identifiers;
- product groups;
- groups of entities.

This extension is attached to an individual BCP-05 vulnerability record and therefore has a different scope.

A single CSAF coordination action may apply to multiple vulnerabilities.

When converting such an action to GCVE records, the converter MAY reproduce the corresponding event in each applicable vulnerability record.

The resulting event identifiers are local to each timeline and need not remain identical across separate vulnerability records.

Product or product-group scoping SHOULD normally be represented using the affected-product information of the containing BCP-05 record rather than duplicated in every timeline event.

1.17 X-03 Semantics Not Fully Represented by CSAF

BCP-05-X-03 contains several concepts that do not currently have a direct equivalent in the CSAF action vocabulary.

These include, in particular:

- explicit embargo agreement;
- embargo extension;
- identifier allocation;
- remediation start;
- mitigation availability;

- distinction between fix development and fix availability;
- advisory publication;
- advisory update;
- case closure;
- structured regulatory applicability assessments;
- regulatory deadlines;
- regulatory submission channels;
- regulatory legal basis.

A converter SHOULD preserve this information in the source representation when a target format cannot express it precisely.

It MUST NOT silently reinterpret a more specific X-03 event as a semantically different CSAF action.

1.18 Embargo Interoperability

Embargo handling is explicitly represented by this extension:

```
embargo-agreed
embargo-extended
```

A CSAF implementation may approximate these events using:

```
category = coordination
```

with additional textual information.

Such conversion is lossy.

An implementation converting from BCP-05-X-03 to CSAF SHOULD preserve the embargo semantics in the CSAF action summary where no dedicated CSAF action category exists.

An implementation converting from CSAF to BCP-05-X-03 MUST NOT infer an embargo merely from a generic coordination action.

1.19 Regulatory Interoperability

A CSAF notification to an entity with category:

```
reporting_authority
```

may indicate that information was sent to a regulator, competent authority, national CSIRT, or another reporting recipient.

This does not provide sufficient information to reconstruct the structured regulatory model defined in this extension.

In particular, a generic CSAF notification does not necessarily identify:

- the regulatory framework;
- the jurisdiction;
- whether the obligation was applicable;
- the legal trigger;
- the awareness timestamp;
- the regulatory deadline;
- the notification type;
- the reporting channel;
- the legal basis; or
- whether the submission fulfilled a regulatory obligation.

A CSAF notification MAY therefore be generated from a regulatory notification for interoperability purposes, but it MUST NOT replace the structured `regulatory` information where that information is available.

Similarly, a generic CSAF notification to a `reporting_authority` MUST NOT automatically be converted to an `EU-CRA` regulatory entry.

1.20 Example: CSAF-aligned Coordination Timeline

The following example demonstrates a coordination timeline using entity and event references.

```
{
  "bcp-05-x-03": {
    "x_timeline": {
      "entities": [
        {
          "id": "entity-researcher",
          "category": "discoverer",
          "name": "Example Researcher"
        },
        {
          "id": "entity-coordinator",
          "category": "coordinator",
          "name": "Example CSIRT"
        },
```

```
        {
          "id": "entity-vendor",
          "category": "vendor",
          "name": "Example Vendor"
        }
      ],
      "events": [
        {
          "id": "evt-1",
          "type": "discovered",
          "timestamp": "2026-08-20T12:00:00Z",
          "actorRefs": [
            "entity-researcher"
          ]
        },
        {
          "id": "evt-2",
          "type": "reported",
          "timestamp": "2026-08-21T08:30:00Z",
          "actorRefs": [
            "entity-researcher"
          ],
          "recipientRefs": [
            "entity-coordinator"
          ]
        },
        {
          "id": "evt-3",
          "type": "acknowledged",
          "timestamp": "2026-08-21T08:45:00Z",
          "actorRefs": [
            "entity-coordinator"
          ],
          "recipientRefs": [
            "entity-researcher"
          ],
          "referencedEvents": [
            "evt-2"
          ]
        },
        {
          "id": "evt-4",
          "type": "affected-party-notified",
          "timestamp": "2026-08-21T09:30:00Z",
          "actorRefs": [
            "entity-coordinator"
          ],
          "recipientRefs": [
            "entity-vendor"
          ]
        },
```

```
        {
          "id": "evt-5",
          "type": "acknowledged",
          "timestamp": "2026-08-21T11:00:00Z",
          "actorRefs": [
            "entity-vendor"
          ],
          "recipientRefs": [
            "entity-coordinator"
          ],
          "referencedEvents": [
            "evt-4"
          ]
        },
        {
          "id": "evt-6",
          "type": "validated",
          "timestamp": "2026-08-22T14:00:00Z",
          "actorRefs": [
            "entity-vendor"
          ]
        },
        {
          "id": "evt-7",
          "type": "fix-available",
          "timestamp": "2026-09-12T09:00:00Z",
          "actorRefs": [
            "entity-vendor"
          ]
        },
        {
          "id": "evt-8",
          "type": "advisory-published",
          "timestamp": "2026-09-12T09:15:00Z",
          "actorRefs": [
            "entity-vendor"
          ]
        }
      ]
    }
  }
}
```

A CSAF implementation could represent much of this sequence using:

```
discovery / completed
notification / completed
confirmation / completed
notification / completed
confirmation / completed
triage / completed
```

```
fix_release / completed
```

but `advisory-published` remains more explicit in X-03.

1.21 Processing and Validation Requirements

1. `events` MUST contain an array of event objects.
2. Every event MUST contain a unique `id`, a `type`, and a `timestamp`.
3. Events SHOULD be ordered chronologically.
4. Producers MUST preserve the factual distinction between report receipt, validation, remediation, availability of a corrective measure, deployment of that measure, and public disclosure.
5. When `entities` is present, every entity MUST contain a unique `id` and a `category`.
6. Every value in `actorRefs` and `recipientRefs` MUST reference an existing entity `id` within the same `x_timeline` object.
7. Every value in `referencedEvents` MUST reference an existing event `id` within the same `x_timeline` object.
8. A `triggerEvent` MUST reference an existing event `id` within the same `x_timeline` object.
9. Regulatory notifications MUST NOT be represented as public disclosure unless the underlying information was actually made public.
10. `dueAt` values SHOULD represent deadlines determined by the producer from the applicable regulatory requirements. Consumers SHOULD NOT independently infer legal compliance solely by comparing `dueAt` and `submittedAt`.
11. Regulatory deadlines MAY depend on facts, exceptions, interpretations, or subsequent regulatory guidance not represented in the vulnerability record.
12. `assessment: applicable` indicates the producer's assessment and MUST NOT be interpreted as a definitive legal determination by downstream consumers.
13. Unknown event types, entity categories, regulatory frameworks, notification types, or fields MUST NOT cause consumers to reject the complete extension.
14. Producers SHOULD include only information that is appropriate for the distribution level of the containing vulnerability record.
15. Producers MUST NOT publish confidential regulatory identifiers, coordination details, personal information, or non-public vulnerability information merely for the purpose of completing the timeline.

16. The presence of an event MUST indicate that the represented event actually occurred.
17. Producers MUST NOT use completion-oriented event types such as `fix-available`, **`public`**`-disclosure`, or `advisory-published` solely to represent planned, outstanding, or in-progress actions.
18. Implementations converting from action-oriented formats MUST preserve the distinction between factual events and workflow state.
19. Cyclic `referencedEvents` relationships SHOULD NOT be produced.
20. Where an event has both a legacy `actor` value and one or more `actorRefs`, those representations SHOULD NOT contradict one another.

1.22 Updates and Corrections

A vulnerability timeline can evolve after publication.

For example:

- active exploitation may be discovered after an advisory has been published;
- additional affected parties may be identified;
- a corrective measure may be replaced;
- a fix may later be deployed;
- regulatory notifications may be updated;
- an embargo may change;
- an earlier assessment may be disputed;
- the advisory may be corrected or expanded.

Producers MAY append additional events to the timeline.

Previously published factual events SHOULD NOT normally be removed.

If an event was incorrect, the publisher SHOULD correct it in a way that preserves sufficient provenance to understand the change when supported by the surrounding publication system.

A later dispute does not necessarily invalidate or remove the earlier event.

For example:

```
validated
   |
   +--> disputed
```

may accurately represent two conflicting factual assertions made at different points in the handling process.

Consumers SHOULD therefore avoid automatically deleting referenced events when a `disputed` event is encountered.

1.23 Privacy and Security Considerations

Vulnerability-handling timelines can reveal sensitive operational information.

In particular, they may disclose:

- when an organization first became aware of a vulnerability;
- the existence of confidential coordination;
- the identity of participating entities;
- vendors or downstream projects that were privately notified;
- failed notification attempts;
- contact relationships between researchers, coordinators, vendors, and authorities;
- regulatory submissions;
- internal remediation activities;
- embargo periods;
- non-public exploitation information; or
- identifiers issued by regulatory platforms.

The optional entity registry increases the ability to represent coordination precisely but also increases the risk of exposing sensitive relationships.

A producer MUST review timeline and entity data before publication.

An entity SHOULD be represented only by its category when publishing its identity would disclose unnecessary or confidential information.

For example:

```
{
  "id": "entity-vendor-2",
  "category": "vendor"
}
```

may be sufficient where publication of the organization's name is inappropriate.

The presence of fields such as `description`, `reference`, `references`, or `notes` MUST NOT be used to publish confidential information that would otherwise be excluded from the vulnerability advisory.

When this extension is used internally before public disclosure, implementations MAY maintain additional non-public events and entities.

These SHOULD be removed, redacted, generalized, or transformed as appropriate before publishing the GCVE record.

The `reference` field of a regulatory notification SHOULD NOT contain confidential CRA SRP submission identifiers unless their publication has explicitly been determined to be appropriate.

Consumers MUST NOT assume that omission of an entity name means that the entity was unknown to the publisher.

1.24 Legal and Regulatory Considerations

This extension is a vulnerability-information interchange format and not a compliance determination mechanism.

Regulatory deadlines and requirements may change through legislation, delegated acts, implementing acts, regulatory guidance, judicial interpretation, or other applicable rules.

Therefore:

- producers are responsible for determining which regulatory obligations apply;
- consumers MUST NOT treat the presence or absence of this extension as evidence of regulatory compliance;
- consumers MUST NOT treat timeline calculations as legal advice; and
- regulatory profiles SHOULD be revised when the applicable framework changes.

The explicit `dueAt` field is preferred over requiring consumers to calculate regulatory deadlines from hard-coded rules.

This allows the format to remain useful when regulatory requirements evolve.

The interoperability guidance relating to CSAF or another vulnerability interchange format is technical guidance only and does not imply regulatory equivalence between the formats.

1.25 Interoperability Considerations

The timeline is intended to complement rather than replace existing BCP-05 and CVE record fields.

The extension SHOULD NOT duplicate:

- vulnerability descriptions;

- affected product information;
- CVSS metrics;
- CWE classifications;
- references already represented by the containing record; or
- KEV assertions.

The optional `entities` registry SHOULD be used only where explicit participant identity or interoperability requires it.

A producer does not need to create an entity object merely because a generic `actor` role is sufficient.

Where active exploitation is established, a publisher SHOULD additionally consider publishing the corresponding machine-readable information using GCVE BCP-07.

BCP-05-X-01 MAY be used when AI-assisted processing contributed to the generation or analysis of timeline information.

BCP-05-X-02 MAY be used when vulnerability metadata or remediation information was derived from analysis of a software patch.

When the containing BCP-05 record is distributed using GCVE BCP-03, this extension forms part of the vulnerability record and SHOULD be preserved by publication, synchronization, storage, and forwarding implementations.

Historical timestamps contained in this extension MUST NOT be interpreted as the publication or synchronization time of the containing BCP-05 record.

1.26 Minimal Example

A producer that only wants to publish the disclosure history MAY continue to use the lightweight representation:

```
{
  "bcp-05-x-03": {
    "x_timeline": {
      "events": [
        {
          "id": "evt-1",
          "type": "reported",
          "timestamp": "2026-08-20",
          "actor": "researcher"
        },
        {
          "id": "evt-2",
```

```
            "type": "acknowledged",
            "timestamp": "2026-08-20",
            "actor": "vendor",
            "referencedEvents": [
              "evt-1"
            ]
          },
          {
            "id": "evt-3",
            "type": "validated",
            "timestamp": "2026-08-22",
            "actor": "vendor"
          },
          {
            "id": "evt-4",
            "type": "fix-available",
            "timestamp": "2026-09-12",
            "actor": "vendor"
          },
          {
            "id": "evt-5",
            "type": "advisory-published",
            "timestamp": "2026-09-12",
            "actor": "vendor"
          }
        ]
      }
    }
}
```

The `entities` registry is not required for simple timelines.

1.27 Minimal Multi-party Example

A producer that needs explicit sender and recipient information MAY use:

```
{
  "bcp-05-x-03": {
    "x_timeline": {
      "entities": [
        {
          "id": "entity-researcher",
          "category": "discoverer"
        },
        {
          "id": "entity-vendor",
          "category": "vendor"
        }
```

```
      ],
      "events": [
        {
          "id": "evt-report",
          "type": "reported",
          "timestamp": "2026-08-20T09:00:00Z",
          "actorRefs": [
            "entity-researcher"
          ],
          "recipientRefs": [
            "entity-vendor"
          ]
        },
        {
          "id": "evt-ack",
          "type": "acknowledged",
          "timestamp": "2026-08-20T10:00:00Z",
          "actorRefs": [
            "entity-vendor"
          ],
          "recipientRefs": [
            "entity-researcher"
          ],
          "referencedEvents": [
            "evt-report"
          ]
        }
      ]
    }
  }
}
```

1.28 Example JSON Paths

The handling events for a vulnerability are located at:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.events
```

The optional entities are located at:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.entities
```

An event's participating actors can therefore be located under:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.events[].
    actorRefs[]
```

Event relationships can be located under:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.events[].
    referencedEvents[]
```

The CRA regulatory timeline is located at:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.regulatory
```

An individual regulatory notification can therefore be located under:

```
containers.cna.x_gcve[0].extensions.bcp-05-x-03.x_timeline.regulatory
    [].notifications[]
```

1.29 Relationship to Other GCVE BCPs

This extension complements:

- **GCVE BCP-02** — defines the practical vulnerability handling and coordinated disclosure process represented by the timeline.
- **GCVE BCP-03** — defines decentralized publication and synchronization of the containing vulnerability record.
- **GCVE BCP-04** — identifier allocation may be represented using the `identifier-assigned` event.
- **GCVE BCP-05** — defines the containing GCVE vulnerability record.
- **GCVE BCP-05-X-01** — can describe AI assistance used during vulnerability analysis or advisory preparation.
- **GCVE BCP-05-X-02** — can preserve provenance where vulnerability information was generated from software patches.
- **GCVE BCP-07** — should be considered when the timeline establishes known exploitation.
- **GCVE BCP-12** — sightings may provide evidence relevant to an `exploit-observed` event.

This extension is intentionally generic enough to represent non-CRA regulatory or contractual vulnerability-reporting timelines in future implementations.

It is also intentionally designed so that factual handling events can be exchanged with coordination-oriented formats such as CSAF without requiring GCVE to adopt their workflow-state model.

GCVE BCP-05-X-04 *Vulnerability Handling and Advisory Publication State* is a separate extension to define current vulnerability-handling or advisory-publication state.